畢業專題 文獻探討
Agentic AI Security

Syu

October 19, 2026

Index

1. Review
2. Pre-Action Authorization
3. MCP Security Framework
4. Learned Capability Governance
5. System-Wide Agent Governance

Review: Agentic AI Security

1. **Agentic AI Security (2510.23883)**
   - Threats: prompt injection, tool abuse, MCP, and multi-agent attacks.
   - Defenses: sandboxing, access control, and runtime monitoring.
2. **Agentic AI and Cybersecurity (2601.05293)**
   - Dual-use agents: autonomous defense and automated exploitation.
3. **Agent-SafetyBench (2412.14470)**
   - Interactive safety evaluation of agent actions and attack scenarios.

Key Takeaway

Agent security requires enforceable controls beyond model-level alignment.

Review: Streamo

Streaming Video Instruction Tuning

- **Problem:** Offline video models and multi-pass pipelines increase response latency.
- **Method:** One-pass inference with three state tokens:
  - `<Silence>`: Continue processing frames.
  - `<Standby>`: Wait for an ongoing event.
  - `<Response>`: Generate an answer.
- **Training:** Streamo-Instruct-465K and focal-weighted LM loss.

Key Takeaway

Streamo prioritizes real-time interaction; Video Streaming Thinking emphasizes longer-term reasoning.

Review: StreamEQA

Streaming Embodied Question Answering

- **Goal:** Evaluate online, first-person video understanding without access to future frames.
- **Embodied dimensions:**
  - Perception, Interaction, Planning.
- **Streaming dimensions:**
  - Backward Reasoning, Realtime Understanding, Forward Prediction.
- **Method:** Extract video metadata, construct QA pairs, and benchmark multimodal models.

Connection

Real-time agent decisions also need safety checks before external actions execute.

Pre-Action Authorization (arXiv 2603.20953)

Before the Tool Call: Deterministic Pre-Action Authorization for Autonomous AI Agents

Uchi Uchibeke
APort Technologies Inc., Toronto, Canada

Abstract

Autonomous agents can invoke powerful tools without a standardized, deterministic authorization boundary.

- **OAP:** Intercepts each tool call before execution.
- Evaluates declarative policies against agent identity, capabilities, and call arguments.
- Produces cryptographically signed audit records.
- **Result:** 53 ms median authorization latency; 0 successful attacks in 879 restrictive-policy attempts.

arXiv: 2603.20953v1

Authorization Model (arXiv 2603.20953)

Deterministic Authorization

$$\text{authorize}(\mathsf{T}, \mathsf{P}, \Pi) \longrightarrow (\mathsf{D}, \mathsf{L})$$

- T: Tool call and arguments; P: Agent passport and capabilities.
- Π: Declarative policies; L: Signed audit log.
- $\mathsf{D} \in \{\text{ALLOW}, \text{DENY}, \text{ESCALATE}\}$.

1. Validate identity, capabilities, and policy constraints.
2. Reject unauthorized arguments or insufficient assurance.
3. Issue a decision before execution and record the result.

Boundary

Deterministic authorization complements, but does not replace, sandbox isolation.

arXiv: 2603.20953v1

Adversarial Evaluation (arXiv 2603.20953)

Results

- **53 ms** median decision latency (N $= 1{,}000$).
- **74.6%** model-level social-engineering success under permissive policies.
- **0/879** attack successes under restrictive OAP policies.

Limitations

- Static policy design; cross-agent delegation is not fully formalized.
- Individually authorized actions may still compose into unsafe workflows.
- Human approval (ESCALATE) is not implemented in the reference system.

arXiv: 2603.20953v1

MCP Threat Modeling (arXiv 2604.05969)

A Formal Security Framework for MCP-Based AI Agents: Threat Taxonomy, Verification Models, and Defense Mechanisms

Nirajan Acharya (University of the Cumberlands)
Gaurav Kumar Gupta (Youngstown State University)

Abstract

MCP tool ecosystems introduce new trust boundaries and fragmented security controls.

- **Taxonomy:** 7 threat categories, 23 attack vectors, 4 attack surfaces.
- **Method:** Labeled transition systems and formal security properties.
- **Analysis:** Comparison of 12 existing defense mechanisms.
- **Proposal:** Four-layer defense-in-depth architecture with 91% theoretical coverage.

arXiv: 2604.05969v1

Formal Verification Model (arXiv 2604.05969)

MCP Model and Labeled Transition System

$$\mathsf{M} = (\mathsf{A}, \mathsf{S}, \mathsf{T}, \mathsf{R}, \mathsf{C}, \ell), \quad \mathsf{LTS} = (\Sigma, \Sigma_0, \Lambda, \rightarrow)$$

A: Agents; S: Servers; T: Tools; R: Resources;
C: Connections; ℓ: Security labels; Σ: System states.

Verified Properties

- **Tool integrity:** Prevent post-approval tool modifications.
- **Data confinement:** Restrict cross-boundary information flows.
- **Privilege boundedness:** Enforce capability limits.
- **Context isolation:** Block unauthorized context sharing.

arXiv: 2604.05969v1

Defense-in-Depth (arXiv 2604.05969)

Proposed Layers

1. Capability-based access control.
2. Cryptographic tool attestation.
3. Information-flow tracking.
4. Runtime policy enforcement.

Coverage Analysis

- No individual defense covers more than **34%** of the identified threats.
- Integrated architecture: **91% theoretical threat coverage**.

Note: Coverage is theoretical, not a measured block rate.

arXiv: 2604.05969v1

Adaptive Least Privilege (arXiv 2604.11839)

Beyond Static Sandboxing: Learned Capability Governance for Autonomous AI Agents

Bronislav Sidik, Lior Rokach
Ben-Gurion University of the Negev, Institute for Applied AI Research

Abstract

Agent runtimes expose excessive tools even for simple tasks, expanding the attack surface.

- **AgentWarden:** Task-aware capability scoping and pre-execution safety routing.
- **Learning:** PPO optimizes tool availability using session audit data.
- **Metric:**

$$\text{SER} = \frac{|\text{Tools invoked}|}{|\text{Tools exposed}|}$$

- **Result:** 73% fewer exposed tools for summarization tasks.

arXiv: 2604.11839v2

MDP and PPO Policy (arXiv 2604.11839)

Markov Decision Process

- **State:** Task category and normalized trust level (7 dimensions).
- **Action:** Binary tool-access mask, $a \in \{0,1\}^{17}$.
- **Policy:** PPO with a two-layer MLP (64 units per layer).

$$R(s,a) = \alpha U_{\text{accuracy}} - \beta C_{\text{economy}} - \gamma P_{\text{safety}}$$

$(\alpha, \beta, \gamma) = (1, 0.3, 5)$.

Runtime Enforcement

Capability Governor limits visible tools; Safety Router checks each proposed call.

arXiv: 2604.11839v2

Evaluation and Failure Modes (arXiv 2604.11839)

OpenClaw Experiments

- **500 tasks:** 400 benign and 100 adversarial.
- **73%** reduction in exposed tools for summarization.
- **26.2%** of 447 intercepted tool calls blocked.
- **92%** of adversarial tasks neutralized by the combined stack.

Key Limitations

- PPO sometimes collapsed to a single-tool policy during real evaluation.
- The system then fell back to YAML-based policies.
- Safety Router training data were small and imbalanced.

arXiv: 2604.11839v2

Cross-Agent Action Governance (arXiv 2609.00015)

OpenAgentFlow: Enabling System-Wide Safety Boundaries for Heterogeneous AI Agent Fleets

Dongsheng Chen (Southern University of Science and Technology)
Xiangyu Zhao (City University of Hong Kong)
Xin Yao (Lingnan University); Xuetao Wei (Southern University of Science and Technology)

Abstract

Individually valid actions can form unsafe workflows across multiple agents and applications.

- Normalize GUI, API, and tool actions into shared **AgentEvents**.
- Enforce policy at a shared **action-commit boundary**.
- Maintain provenance, session state, and audit records outside individual agents.
- **Result:** 97.62% accuracy on 1,220 AgentDojo-Traj cases.

arXiv: 2609.00015v2

Shared Policy Enforcement (arXiv 2609.00015)

Control Plane / Action Plane

- **Control plane:** Policies, provenance, session state, audit records.
- **Action plane:** Shared Policy Enforcement Point (PEP).
- **Action-commit boundary:** Inspect an action before side effects occur.

Policy Decision Stages

1. T1: Structured policy rules.
2. T2: Payload and provenance checks.
3. T3: Semantic assessment when rules are insufficient.
4. T4: Final adjudication and escalation.

arXiv: 2609.00015v2

System Evaluation (arXiv 2609.00015)

Results

- **300-case controlled suite:** 94.00% accuracy; 95.35% attack-block rate.
- **1,220-case AgentDojo-Traj:** 97.62% accuracy.
  - 96.59% unsafe-action recall.
  - 1.96% false intervention on safe actions.
- Demonstrated policy updates and enforcement on Android action paths.

Key Challenge

Effective protection depends on complete event capture and accurate cross-step provenance.

arXiv: 2609.00015v2